CineConnect - Production readiness audit

Fresh review of the deployed service, application controls and launch operations.

cine.nalexustechnologies.com | 14 October 2026

DECISION	PUBLIC PRODUCTION LAUNCH
NO-GO	Confirmed account, privacy and authorization defects remain. Passing tests and a healthy API do not override these findings.

CRITICAL	HIGH	MEDIUM	LOW
1	13	13	1

Most urgent evidence

- 173 active accounts match source-known demo password defaults, including 4 super-admin role assignments.
- An unprivileged local account can read the daily production SQL backup.
- Anonymous cinema results expose budget fields for 8 member-only projects.
- Isolated probes reproduce safety authorization bypasses and payment self-approval.

28 prioritized findings. Every finding includes evidence, impact, a responsible function, a proposed correction and acceptance checks. Native distribution and optional providers are explicitly scoped.

Release: 2026.10.14-audit2 Commit: 59c4791e67aa9609c72d1f5bcff5ea696f10bfcd Branch: fix/audit-connectivity-2026-10-13

This audit performed no production business-data mutations, deployments, credential changes or outbound email/SMS. Security mutations ran only in a temporary local SQLite database.

1. Release decision

The service is running and substantial backend connectivity is implemented. The fresh review nevertheless identifies defects that make unrestricted public use inappropriate until corrected. This report supersedes any inference that completion of the earlier static-data remediation alone establishes production readiness.

Launch mode	Assessment	Required decision
Public web	Not ready	Close the critical/high web findings and validate the complete browser acceptance matrix.
Restricted internal pilot	Conditional	First remove known-default access, protect backups and private data, and constrain participation to approved accounts. This is not a production sign-off.
Native Android/iOS	Not ready	Meet web/backend gates plus release signing, identity, provisioning and physical-device/store checks.
Manual payments / KYC	Conditional	Independent staffed verification, evidence retention and escalation must be demonstrated.
SMS / native push / optional features	Unavailable or unverified	Do not advertise capabilities that lack a provider or implementation. Browser push is configured but display is unverified.

Recommended execution order

• Immediate containment: PR-01, PR-02, PR-03, PR-04 and PR-05. Preserve incident evidence and change records while removing access/exposure.

• Before onboarding: PR-06 through PR-11, plus privacy procedures (PR-21) and browser acceptance (PR-22). Review and accept or resolve remaining medium risks with named owners.

• Before scale or native distribution: complete capacity tests, reproducible builds, queue recovery and native signing. Re-audit the deployed release after remediation.

Severity and confidence

Severity is an engineering launch priority, not a calculated CVSS score. Critical means an immediate broad compromise path; High means a launch-blocking confidentiality, integrity, availability or acceptance gap. Medium requires correction or explicit risk ownership. Low is supporting release quality. Conditional findings block only their stated release scope.

Confirmed live = observed against the deployed service or read-only host/database state. Confirmed isolated = reproduced on the current source using synthetic local data. Source review = supported by inspected implementation. Verification gap = an outcome that has not been established; it is not proof of a defect.

2. Scope and evidence quality

Inventory	Observed scope
Source	980 tracked files; 477 Dart app files; 74 backend app Python files; 57 Flutter test files and 42 backend test files.
Application surface	15 feature directories, 17 configured role codes (13 publicly selectable and 4 internal staff codes).
API / database	390 versioned API operations across 20 API groups; 160 modeled business tables and 161 live database tables including migration metadata.
Deployment	Nginx HTTPS + Flutter web; API, Celery worker and scheduler containers; shared-host MySQL, Redis, ClamAV and local file storage.
New evidence	Live HTTP/TLS/control checks, host/container settings, read-only database aggregates and hash verification, package advisory queries, route/schema comparison and 11 isolated policy probes.
Recent evidence retained	Same-commit Flutter/backend tests, lint/type checks, web build and source/release integrity evidence from the preceding remediation verification. These were not rerun wholesale.

How the audit was bounded

Fresh evidence was collected on 14 October 2026, approximately 15:39-15:52 UTC (20:39-20:52 Pakistan time), with timestamps in individual JSON files. Configuration and route enumeration were broad; security probes and detailed code review were risk-directed. Every screen, record and interleaving was not manually exercised.

No brute-force login, live payment, destructive database operation, sustained production load or paid AI request was performed. The password check compared existing hashes against source seed defaults inside the deployed container and emitted only aggregate counts. No passwords/hashes, private keys or personal account identifiers are in this report.

The local policy probes use SQLite and synthetic records. They establish deterministic authorization/serialization behavior, not MySQL concurrency guarantees. Browser automation was unavailable; screenshots from old reports are not presented as fresh verification.

OWASP ASVS 5.0 is a review lens for authentication, authorization, data protection and operations. This is not an exhaustive ASVS compliance assessment, penetration-test certification or legal opinion. See reference R7.

3. Deployed system and controls

Control / component	Fresh or recent evidence	Assessment
HTTPS	TLS 1.3; certificate expires 14 Dec 2026; HTTP redirects 301 to HTTPS; Certbot timer exists.	Working; renewal failure drill not run.
Readiness	/health/live and /health/ready return 200; database and Redis report OK.	Limited dependency coverage.
Network boundary	API 127.0.0.1:5002; Redis loopback; ClamAV 127.0.0.1:3310. MySQL public TCP 3306 reachable.	Database boundary needs correction.
Authentication	Five fresh private endpoint samples returned 401. Staff roles excluded from public role catalogue.	Positive baseline; existing demo accounts remain critical.
CORS	Untrusted Origin received no allow-origin response header.	Positive sampled control.
Files	237 clean/ready files; ownership and quarantine gates in source; live ClamAV services active.	239 historical missing files remain; MIME/quotas need work.
Encryption / secrets	Secret/JWT lengths meet configured >=64 check; private-field key and VAPID files configured; production env is 0600.	Key rotation/recovery not demonstrated.
Containers	Run as cineconnect; unless-stopped policy; all three running with 0 restarts.	No health check, resource caps or log rotation.
Rollback	Previous release assets and protected database/storage snapshots retained. Earlier deployment rollback exercised.	Useful release recovery; not a full host-loss restore.

Source release: /var/www/cineconnect/releases/20261014-audit2. Live release and web symlinks point to this release. Backend image: cineconnect-prod-api:20261014-audit2. Migration: 9f84c2e7a6b1.

Recent provenance evidence records image SHA-256 1ebed18aee51668e478bb155f766ed768c97adab74018dc3a67ba0c8adb6087f and main.dart.js SHA-256 0c89dcea93f34036cf387e917490447019f8d6334cb1a8658bfedff09a2ff0d6. The current audit verifies the release label/configuration; those content hashes are retained evidence from the same release.

4. Data readiness and trust

Database measure	Count / result	Meaning
Active users	240 of 240	No suspended user was present in this snapshot.
Seed-default hash matches	173 accounts	Critical access risk; role-assignment counts are not distinct-user totals.
Demo email domain	122 accounts	Does not identify every synthetic record.
Projects / listings	64 / 149	Counts establish persistence, not real-user provenance.
Bookings / contracts / payout accounts	42 / 12 / 10	Not reconciled to external banks or contract owners in this audit.
Clean files	207 public + 30 authorized	Real scan/processing states are present.
Missing files	239 private	Already flagged missing; must not be treated as available evidence.
KYC submissions	102 approved; 12 submitted	144 document references under approved submissions point to missing files.
Incomplete expired uploads	37	Retention/reconciliation needs an owner and job.
User sessions / notifications	303 / 68	Session count includes historical rows; it is not a count of currently logged-in people.

What “connected” now means

A screen returning database-backed data can still show demonstration content. The audit separates connectivity from authenticity, completeness and business trust. Demo credentials, seeded KYC, missing documents and public/private publication rules require explicit migration decisions before real users rely on the marketplace.

Historical cleanup retained as an open dependency

The prior remediation identified 18 placeholder private values requiring owner re-entry: 4 location addresses, 2 equipment serials, 6 safety coordinates, 1 brand billing value, 2 distributor contact values and 3 insurance licence values. That evidence is retained from the same release; individual values were not re-entered during this audit.

No production record was deleted or reclassified by this audit. Remediation should preserve necessary evidence and distinguish verified business data from seeded fixtures.

5. App-wide review matrix

“Baseline” below means recent automated evidence for this commit, supplemented by current source review. It is not a fresh manual sign-off of every button.

Area / roles	Backend and baseline	Current readiness concern
Auth, settings, profiles	Auth/settings API; sessions and role guards tested.	Demo passwords, recovery, replay, policy consent.
Director / producer	Projects, requirements, members, bookings and dashboard persisted.	Public cinema privacy; pagination; browser acceptance.
CinePlanner	32 API operations; AI stages, production planning and exports.	Queue latency/durability; real AI/cost and concurrent editing not exercised.
Actor / talent / model / influencer	Profiles, rates, availability, applications and self-tapes.	Demo identity evidence; self-reported social metrics; native media checks.
Casting agency	Roster, opportunities, casting applications and invitations.	Domain flows have baseline tests; real role walkthrough remains open.
Brand / sponsor	Campaigns, applications, offers and finance records.	Manual settlement, authentic production data and browser acceptance.
Location owner	Properties, spaces, pricing, rules, inspections and claims.	Private-field re-entry; evidence files; safety permission gap.
Equipment / crew	Inventory, packages, inspections, availability and jobs.	Serial placeholders; uploads; cross-role/device acceptance.
Legal / contracts	Templates, signatures, PDF downloads and verification links.	Legal approval/retention and real signing/download experience.
Insurance / safety	Policies, permits, incidents and checklist workflows.	Safety mutation controls and missing historic evidence.
Distribution / public cinema	Release planning, contacts, analytics and public feed.	Confirmed private metadata exposure; external-provider review.
Bookings / payments	Offers, contracts, proofs, receipts and ledger.	Self-review; external bank reconciliation/concurrency not proven.
Messaging / trust / support	Threads, disputes, moderation, tickets and notifications.	Manual deletion handling; delivery/retention and queue monitoring.
Super-admin / reviewer / finance / support	Admin control, role permissions, analytics and exports.	Default staff access, permission semantics and missing audit mutations.

6. Verification results

Recent same-commit check	Result	Interpretation
Flutter analyze / tests	Clean / 920 passed	Widget and unit coverage; does not prove a live browser session.
Flutter web release build	Passed	JavaScript build succeeded; dependency-related Wasm warning retained.
Backend full suite	391 passed, no skips	MySQL 8.4 + Redis isolated environment; 579.27 seconds.
Coverage	85.75% combined	90.08% statement; 68.90% branch. Gate is 85% combined.
Ruff + mypy	Passed	161 formatted/checked files and 74 typed source files in retained logs.
Push worker Node regression	1 test passed	Lifecycle logic only; real browser display still pending.

Fresh isolated policy probes: 11 checks, 8 issue reproductions

Probe	Result
Read-only member changes safety risk/completion	200; should deny
Read-only member removes mandatory checklist requirement	200; should deny
Removed member creates safety check	201; should deny
Zero-permission support role reads user directory	200; policy/configuration mismatch
Ordinary member changes project settings	403; expected
Unrelated support role reads private safety check	404; expected
Authorized admin suspends synthetic account	200; expected
Suspension creates visible admin audit event	0 before / 0 after; missing event
Old refresh token replay	Rejected, but active family not revoked
Private member-only external trailer in public feed	Returned with private budget
Admin submits and approves own payment proof	200; should require independent review

Expected outcomes are the security/operational policies recommended by this review. The fine-grained admin-permission case requires an explicit product policy decision; current behavior is proven. Synthetic SQLite tests do not establish MySQL race behavior.

7. Finding register - launch risks

ID	Priority	Finding	Primary owner
PR-01	Critical	Active accounts retain source-known demo passwords	Security + operations
PR-02	High	Daily SQL backup is readable by unrelated local users	Infrastructure + security
PR-03	High	Public cinema ignores private project and file visibility	Backend + product privacy
PR-04	High	Safety editing and removed-member checks are inconsistent	Backend + safety operations
PR-05	High	Payment reviewers can approve their own submitted proof	Payments + finance operations
PR-06	High	All proxy clients share loopback rate-limit identity	Backend + Nginx
PR-07	High	MySQL is reachable on the public server interface	Infrastructure + database owner
PR-08	High	Recovery coverage falls short of the documented targets	Infrastructure + backup owner
PR-09	High	Production verification data still contains demo and missing evidence	Data owner + verification operations
PR-10	High	Self-service email verification and password recovery are unavailable	Product operations + backend
PR-11	High	Health checks do not prove end-to-end service operation	SRE / operations
PR-12	Medium	Shared-host resource limits and Docker log rotation are absent	Infrastructure
PR-13	Medium	Browser application responses lack protective web headers	Web + Nginx
PR-14	Medium	Editable admin permissions do not govern all admin access	Backend + access-control owner

All findings are open at publication. High native-only and provider-dependent findings are conditional on release scope. No change was deployed during this audit.

8. Finding register - hardening and release

ID	Priority	Finding	Primary owner
PR-15	Medium	Sensitive admin changes are absent from the audit feed	Backend + security operations
PR-16	Medium	Refresh replay rejection does not revoke the active token family	Authentication
PR-17	Medium	Runtime database account has schema-changing privileges	Database + deployment
PR-18	Medium	Queue durability and long-running worker isolation need validation	Backend + operations
PR-19	Medium	Deployed Python packages have outstanding advisory matches	Dependencies + security
PR-20	Medium	Release reproducibility and supply-chain checks are incomplete	Build / release engineering
PR-21	High	Privacy, consent and retention procedures lack release evidence	Product + privacy/legal owner
PR-22	High	Real-browser and device release acceptance remains incomplete	QA + product owner
PR-23	Medium	Pagination is inconsistent and hides older admin records	Backend + admin UI
PR-24	Medium	Uploads lack account storage budgets and type-content validation	File pipeline + infrastructure
PR-25	Low	OpenAPI omits 119 implemented API operations	API documentation
PR-26	High	Android release configuration still uses debug signing	Mobile release engineering
PR-27	Medium	Provider-dependent and unsupported features need explicit launch scope	Product + integrations
PR-28	Medium	Capacity, concurrency and end-to-end regression evidence is insufficient	QA + performance engineering

Use the acceptance checks on the following pages as remediation exit criteria. A green test suite alone is insufficient when the relevant negative cases are absent.

Finding details / PR-01 - PR-02

PR-01 | CRITICAL | Active accounts retain source-known demo passwords

Confirmed live, hash verification only • Security + operations • Public web launch

Evidence. runtime-data.json: 173 of 240 active accounts match two seed-script password defaults. Matching active role assignments include 4 super_admin, 3 finance_admin, 3 reviewer and 3 support_agent. Role counts may overlap accounts. No password, hash or account identifier is included in this report.

Impact. Knowledge of a source default can permit account takeover, including administrative access. Blocking public self-registration of staff roles does not protect already seeded privileged users. This is the strongest immediate release blocker; no successful attacker access is claimed.

Required correction. Identify affected accounts privately; disable unused demo accounts, replace required staff credentials with unique values, revoke their sessions and review authentication/admin history. Separate seed data from the production environment and require explicit safe seeding controls.

Acceptance. Zero active production accounts match any seed default. Every retained staff account has a verified owner; existing sessions are revoked after remediation; login and admin access are retested with unique credentials.

PR-02 | HIGH | Daily SQL backup is readable by unrelated local users

Confirmed live permission test • Infrastructure + security • Public web launch

Evidence. backup-permissions.json: /var/backups/cineconnect is mode 0775 and the 20261014 daily SQL gzip is 0644. runuser -u nobody -- test -r returned true. Current production env and the newer manual audit backup directory are protected; the exposure is the daily backup path.

Impact. A compromised application or ordinary account on this shared host can read the database dump, including account hashes, session metadata and application records. This was a readability check, not a download of customer data. Encrypted fields alone do not make the entire SQL archive safe.

Required correction. Use a dedicated backup identity, restrictive directory/file permissions and umask 077 in the scheduled job. Encrypt off-host archives and review historical daily backups for the same exposure. Keep current production secrets and rollback backups restricted.

Acceptance. An unprivileged account cannot list or read backup contents. A newly scheduled backup has the intended owner/mode, passes integrity checks and can be restored by the recovery operator.

Finding details / PR-03 - PR-04

PR-03 | HIGH | Public cinema ignores private project and file visibility

Confirmed live + isolated reproduction • Backend + product privacy • Public web launch

Evidence. projects.py:161 and 635: public_cinema filters folder/status/media readiness but not Project.visibility or ProjectFile.visibility. Live anonymous results contained 8 member-only projects and 8 budget values. A private project with a member-only external trailer was returned in the isolated probe.

Impact. An authenticated member can create content that is later exposed publicly with project description, budget, schedule and member counts. An external video link being reachable elsewhere does not authorize publication of its surrounding private project metadata.

Required correction. Require explicit publication consent and both project/file visibility gates. Use a minimal public serializer that excludes budgets and internal project state by default. Review existing cinema records and publication controls before migration.

Acceptance. Anonymous callers see no private/member-only project or file in the cinema feed. Private budgets remain absent even when an owner intentionally publishes a trailer. Negative cases cover external URLs and uploaded files.

PR-04 | HIGH | Safety editing and removed-member checks are inconsistent

Confirmed isolated reproduction • Backend + safety operations • Public web launch

Evidence. operations.py:124, 1599 and 1624. A read-only member changed risk/status and made a mandatory checklist item optional (HTTP 200). A removed project member created a safety check (HTTP 201). _project_for_member omits member status; update handlers reuse a view-access helper.

Impact. View access can be used to falsify operational safety state, and revoked project membership does not consistently stop new safety records. The unrelated-user read check passed, so this is a specific authorization gap rather than unrestricted public access.

Required correction. Create distinct read/create/edit/approve policies. Require active membership plus an authorized responsible person or safety role for mutations. Apply the same rule to incidents and checklist items; preserve auditable completion history.

Acceptance. Read-only and removed members receive 403/404 on all unauthorized mutations. Owners and assigned safety staff succeed. Tests cover revocation, insurance viewers, reviewers, mandatory-item changes and completion transitions.

Finding details / PR-05 - PR-06

PR-05 | HIGH | Payment reviewers can approve their own submitted proof

Confirmed isolated reproduction • Payments + finance operations • Public web launch

Evidence. payments.py:64 and 577: the decision endpoint checks a finance/admin/reviewer role without checking submitter or booking-party conflicts. An isolated super-admin payer approved their own pending proof with HTTP 200; the posting service creates a receipt and secures the booking.

Impact. The manual payment process lacks separation between submission and verification. A privileged participant can mark their own transfer verified without an independent reviewer. This audit did not move money or test a real bank transfer.

Required correction. Reject review by the submitter, payer, payee or other disallowed conflicted party. Define an independent reviewer policy and an auditable exceptional approval path if the business requires one. Review whether ordinary reviewer roles should access finance decisions.

Acceptance. Self-approval and conflicted approval return 403. A different authorized finance reviewer can approve verified evidence, producing one receipt and balanced expected ledger entries. Concurrent duplicate decisions are tested against MySQL.

PR-06 | HIGH | All proxy clients share loopback rate-limit identity

Confirmed deployed code + request-context probe • Backend + Nginx • Public web launch

Evidence. extensions.py:15 uses get_remote_address; create_app has no trusted proxy normalization. Nginx proxies via 127.0.0.1. Two different forwarded client IPs both produced the limiter key 127.0.0.1. auth.py applies login 10/minute, registration 20/hour and reset 10/hour limits.

Impact. Different users compete for the same per-endpoint quota, making login and registration susceptible to cross-user lockout. Raw forwarded headers are also recorded in auth metadata without trusted normalization. No production limit was deliberately exhausted.

Required correction. Configure a precisely trusted proxy boundary and normalize client IP before throttling/audit recording. Use account-aware limits where appropriate and preserve spoofing protection. Do not trust arbitrary caller-supplied X-Forwarded-For values. See reference R1.

Acceptance. Two real client addresses have independent quotas; repeated attempts from one address are limited. Forged forwarding headers cannot bypass the policy. Login, registration, reset and uploads retain useful abuse protection.

Finding details / PR-07 - PR-08

PR-07 | HIGH | MySQL is reachable on the public server interface

Confirmed live configuration + TCP connection • Infrastructure + database owner • Public web launch

Evidence. The host listener is 0.0.0.0:3306 and UFW allows TCP 3306 from Anywhere (IPv4). A TCP connection from this audit workstation to srv951538.hstgr.cloud:3306 succeeded. API and Redis listeners are loopback-only. MySQL app transport currently negotiated TLS.

Impact. The database has an unnecessary broad network attack surface for an app running on the same host. TLS is positive but does not replace network access control. This host serves other apps, so database access requirements must be inventoried before restrictions change.

Required correction. Restrict database access to loopback/private networking and specifically approved administration sources. Review database host grants and external consumers. Apply changes through a reversible maintenance procedure that preserves other services.

Acceptance. Unapproved external connections to 3306 fail; CineConnect and every approved database consumer remain healthy. Approved remote administration uses a controlled tunnel or explicit allowlist.

PR-08 | HIGH | Recovery coverage falls short of the documented targets

Confirmed configuration; restore outcome unverified • Infrastructure + backup owner • Public web launch

Evidence. Root cron runs a daily database dump at 02:00 UTC; the latest gzip passed integrity checking. Its script has no storage or off-host copy stage. No scheduled CineConnect storage/off-host job was found in inspected cron/timers. docs/DEPLOYMENT_INPUTS.md specifies 15-minute RPO and 4-hour RTO.

Impact. Daily local SQL backups leave up to roughly one day of database change at risk and do not protect against host loss. Uploaded documents need their own coordinated recovery. Recent manual database/storage snapshots and rollback assets help deployment recovery but are not a continuous disaster-recovery system.

Required correction. Implement encrypted off-host database backups, appropriate point-in-time recovery and scheduled file backups. Define ownership, retention and alerts. Perform a full isolated restore including encryption keys, uploaded files, migrations and app startup.

Acceptance. A timed restore demonstrates the approved RPO/RTO, including a recent upload and transaction. Backup failure alerts reach an owner; restoration succeeds after simulated loss of the original host without using that host as the only key source.

Finding details / PR-09 - PR-10

PR-09 | HIGH | Production verification data still contains demo and missing evidence

Confirmed live aggregates • Data owner + verification operations • Public web launch

Evidence. data-integrity.json and runtime-data.json: 122 accounts use the demo email domain; 239 private file rows are marked missing. There are 144 document references on approved KYC submissions whose files are missing. There are 102 approved KYC submissions overall. These are counts, not proof of real identity fraud.

Impact. Backend-connected records can still be synthetic, incomplete or unsuitable for production trust claims. Approved KYC states without underlying evidence should not authorize real business activity without a documented decision. Historical private-field placeholders also need owner re-entry.

Required correction. Classify retained demonstration records, exclude them from real-user discovery/metrics, and migrate only reviewed business data. Re-verify affected identities and request replacement evidence. Preserve required history rather than silently deleting records.

Acceptance. Every production-approved KYC decision has accessible authorized evidence or a documented exception. No demo listing is presented as a verified real provider. Missing files and the 18 previously identified private-field placeholders have a tracked disposition.

PR-10 | HIGH | Self-service email verification and password recovery are unavailable

Confirmed live capability/configuration • Product operations + backend • Public web launch

Evidence. Live bootstrap reports email=false. SMTP_HOST and SMTP_FROM are unset. The user confirmed no SMTP/SMS/native-push provider is currently configured. Auth email delivery exists in source but cannot operate without the service.

Impact. Users can lose account access without a functioning recovery channel. Stronger password rotation for PR-01 requires a safe enrollment/recovery process. This is a known operational dependency, not a claim that the UI falsely reports email delivery.

Required correction. Configure a production email provider with authenticated sending and monitored delivery, or formally constrain launch to a staffed verified recovery process. Establish account ownership checks and escalation procedures before onboarding.

Acceptance. A real user receives verification and reset messages; tokens expire and are single-use, and link handling works in supported browsers. Delivery failures are observable. An alternative manual process is documented, staffed and demonstrated if chosen.

Finding details / PR-11 - PR-12

PR-11 | HIGH | Health checks do not prove end-to-end service operation

Confirmed configuration; external monitoring unverified • SRE / operations • Public web launch

Evidence. SENTRY_DSN is unset. All three app containers have no Docker health check. /health/ready checks only database and Redis, not queue processing, file scanning, email, disk or scheduler freshness. Containers were running with zero restarts and no API tracebacks/500 lines in the sampled 30 minutes.

Impact. The status endpoint can remain green while uploads or notifications stop processing. No tested alert route or on-call acknowledgement was demonstrated. Generic host monitoring snippets exist; their app-specific coverage was not established.

Required correction. Add app-specific external probes and alerts for errors, queue age, failed tasks, antivirus freshness, disk, backup age and scheduler activity. Define an on-call owner and response runbook; include a synthetic safe workflow.

Acceptance. A controlled staging failure of each critical dependency triggers an actionable alert and recovery runbook. Production monitoring reports freshness and failures without logging credentials or sensitive payloads.

PR-12 | MEDIUM | Shared-host resource limits and Docker log rotation are absent

Confirmed live runtime configuration • Infrastructure • Public web launch

Evidence. Infrastructure snapshot: root disk 86% used, 28 GiB available; RAM available about 3.1 GiB of 16 GiB; 2 GiB swap fully used. API/worker/scheduler have memory=0, nano_cpus=0, no PID cap and json-file logging without options. No daemon.json logging policy exists.

Impact. A busy job, noisy log or another service can consume shared resources and affect multiple apps. Full swap is a capacity warning, not evidence of an outage; current app log files were small. Disk exhaustion would affect uploads, database writes and backups.

Required correction. Set measured per-service limits and reserved headroom, log size/count rotation and disk alerts. Review old releases/backups with retention rules and owner approval. Keep evidence and rollback assets required by policy. See reference R2.

Acceptance. Limits and rotation appear in running container inspection; a staging resource test degrades safely. Disk growth has a monitored budget and cleanup ownership. Production remains healthy after container recreation.

Finding details / PR-13 - PR-14

PR-13 | MEDIUM | Browser application responses lack protective web headers

Confirmed fresh HTTP responses • Web + Nginx • Public web launch

Evidence. GET / returned no Content-Security-Policy, X-Frame-Options, Strict-Transport-Security, X-Content-Type-Options or Referrer-Policy. API responses do include these controls. Several static location blocks define their own headers.

Impact. The actual page hosting authentication lacks framing and script-source protections even though the API has them. A successful HTTPS visit to the HTML entry point alone does not set HSTS. This audit did not demonstrate a working script-injection exploit.

Required correction. Apply tested page headers across all web entry points, accounting for Nginx inheritance. Design a CSP compatible with Flutter, CanvasKit, uploads, media and intended third-party content. Preserve camera/microphone permissions needed by approved workflows.

Acceptance. HTML/deep links and assets have the expected headers. Framing is blocked and CSP violations are reviewed in a real browser. Login, media, file selection, camera and exports still work.

PR-14 | MEDIUM | Editable admin permissions do not govern all admin access

Confirmed isolated behavior and source review • Backend + access-control owner • Public web launch

Evidence. admin_control.py:46 uses fixed role membership for most access; the same module exposes editable RolePermission records. A support_agent with zero assigned permissions still received the account directory (HTTP 200). policies.py permission checks are used elsewhere, such as KYC.

Impact. Operators may believe removing a permission removes access, while fixed role guards continue to allow it. This is a policy/UI inconsistency; static role access may be intentional, but its precedence must be explicit and tested.

Required correction. Define one authoritative role/permission model. Either enforce fine-grained permissions on relevant endpoints or remove misleading configuration for immutable role powers. Review access to user email, finance, reports and moderation separately.

Acceptance. A documented role matrix matches API behavior. Removing an editable permission revokes the corresponding capability on the next request; unsupported combinations cannot be saved in the admin UI.

Finding details / PR-15 - PR-16

PR-15 | MEDIUM | Sensitive admin changes are absent from the audit feed

Confirmed isolated reproduction • Backend + security operations • Public web launch

Evidence. admin_control.py:338 changes user status and roles without an audit-event write. An isolated account suspension returned 200 but /admin/control/audit-events stayed at zero events. The feed currently combines KYC, booking, payment and moderation history.

Impact. Investigators cannot reliably reconstruct who suspended an account or changed staff access using the advertised audit history. Existing event tables do not substitute for coverage of each privileged mutation.

Required correction. Record actor, target, before/after state, reason, timestamp and request ID for privileged changes. Cover permissions, fee rules and contract templates as well as users. Apply retention and access rules; avoid secret or document payloads in events.

Acceptance. Every tested sensitive admin mutation produces exactly one durable event with the responsible actor, and unauthorized attempts are observable. Events can be retrieved beyond the feed display limit without being overwritten by later state changes.

PR-16 | MEDIUM | Refresh replay rejection does not revoke the active token family

Confirmed isolated reproduction • Authentication • Public web launch

Evidence. security.py:143 stores previous_refresh_token_hash but only queries the current hash when rotating. The isolated probe rejected reuse of the old token while leaving the related session unrevoked. Rotation has no explicit row lock in this code path.

Impact. If a refresh credential is stolen and rotated by an attacker, later replay by the legitimate holder does not invalidate the attacker-held successor. Existing expiry, session checks and password fingerprint checks provide useful protections but do not resolve this case.

Required correction. Detect replay of prior tokens and revoke the relevant family with an auditable event. Handle concurrent legitimate refresh calls deliberately; test atomic rotation on MySQL. Retain only bounded hashed history.

Acceptance. A reused token is rejected and invalidates its family according to the documented policy. Concurrent refresh tests do not leave multiple valid successors or produce uncontrolled 500 responses.

Finding details / PR-17 - PR-18

PR-17 | MEDIUM | Runtime database account has schema-changing privileges

Confirmed live grants • Database + deployment • Public web launch

Evidence. runtime-privileges.json shows the app identity has CREATE, DROP, ALTER, EVENT, TRIGGER and routine/view privileges on its database, in addition to data access. Global privileges showed USAGE. No database alteration was performed by the audit.

Impact. Compromise of the runtime app can have a larger destructive impact than ordinary data reads/writes. Deployment migrations need broader privileges, but every API and worker process does not need to retain those powers.

Required correction. Use separate runtime and migration database identities. Reduce runtime grants to demonstrated application requirements, and keep elevated deployment credentials outside ordinary app containers.

Acceptance. The app passes its integration suite with reduced grants. Runtime DROP/ALTER/GRANT attempts fail in staging while an authorized migration job can upgrade and validate the schema.

PR-18 | MEDIUM | Queue durability and long-running worker isolation need validation

Confirmed configuration; failure behavior not exercised • Backend + operations • Public web launch

Evidence. Redis reports AOF disabled and successful RDB snapshotting. Celery tasks share the default queue; the worker has concurrency 2. Screenplay calls allow a 900-second timeout with retries. No explicit task time limits or task routing were found in celery_app.py.

Impact. A crash can lose work since the last Redis snapshot, and slow AI jobs can delay file scans or notifications. At-least-once redelivery and long tasks require idempotency and timeout alignment. Queue length was zero at the sampled instant; no backlog outage is claimed.

Required correction. Define acceptable broker data loss, durable task reconciliation, separate latency-sensitive queues and bounded task execution. Add queue-age alerts and retry/dead-letter handling. Validate Redis visibility timeouts against the longest job. See reference R3.

Acceptance. Staging worker/broker restarts preserve or reconcile every accepted job. Duplicate execution does not duplicate business effects. Upload scans and push remain within their service targets while AI workers are busy.

Finding details / PR-19 - PR-20

PR-19 | MEDIUM | Deployed Python packages have outstanding advisory matches

Confirmed package inventory + advisory scan • Dependencies + security • Public web launch

Evidence. pip-audit checked 87 third-party installed distributions from an 88-package inventory. It returned 14 records representing 7 distinct IDs in cryptography 49.0.0 and pip 25.0.1. cryptography is constrained below 50 in pyproject.toml, excluding the reported fix.

Impact. A vulnerable version match needs reachability triage. The cryptography issue concerns PKCS#7 decryption; app private fields use Fernet and no pkcs7_decrypt call was found. pip issues concern package installation, not an exposed app route. No successful exploitation was demonstrated.

Required correction. Review and update to compatible fixed versions, including changing the cryptography upper bound after regression testing. Update the build toolchain and generate a pinned inventory. Record justified non-reachability decisions and scan the rebuilt image.

Acceptance. Rebuilt Python inventory has no unresolved actionable advisories. Version exceptions have owners and expiry dates. The full backend suite, encryption round trips and push signing pass with the chosen versions. See references R4-R6.

PR-20 | MEDIUM | Release reproducibility and supply-chain checks are incomplete

Confirmed source configuration • Build / release engineering • Public web launch

Evidence. Dockerfile uses python:3.12-slim without a digest and installs range-constrained dependencies from pyproject.toml. No production Python lock/hash file is used by that build. CI runs tests and coverage, but the inspected workflows do not run dependency/container advisory scans.

Impact. Rebuilding the same Git commit can resolve a different runtime. Current deployed image identity is recorded, which helps rollback, but future reproducibility and base-image advisory coverage remain incomplete. The host OS/container OS were not fully vulnerability-scanned in this audit.

Required correction. Pin reviewed dependencies and base image digests, retain an SBOM and build provenance, and gate on actionable package/base-image findings. Review action pinning and release approval ownership. Keep the existing 85% combined coverage gate.

Acceptance. A clean build is traceable to source and dependency hashes. CI publishes an SBOM, advisory results, tests and immutable image digest. Promotion and rollback use reviewed artifacts, not an uncontrolled rebuild.

Finding details / PR-21 - PR-22

PR-21 | HIGH | Privacy, consent and retention procedures lack release evidence

Source-confirmed gaps; business approval unverified • Product + privacy/legal owner • Public web launch

Evidence. Registration displays agreement text without a linked policy in the inspected checkbox; auth_controller.dart submits a fixed 2026-07 terms version and backend requires only a nonempty version. Account deletion creates a support request. Retention is described in docs, but no retention task appears in Celery scheduling; 37 expired incomplete uploads remain.

Impact. A user request is recorded, but completion, exceptions and deletion across storage/backups are not demonstrated. The report evaluates implementation and operational readiness, not legal compliance or the legal validity of contracts.

Required correction. Publish approved, versioned policies and link them at consent points. Validate accepted versions server-side. Implement a staffed deletion/export process and retention jobs with legal-hold exceptions, evidence and service deadlines.

Acceptance. Users can read the exact terms they accept. A test deletion/export case completes across relevant stores with a documented retained-data exception list. Retention jobs are monitored and cannot remove held records.

PR-22 | HIGH | Real-browser and device release acceptance remains incomplete

Verification gap confirmed • QA + product owner • Public web launch

Evidence. The fresh CUA inventory returned no browsers/apps and a native pipe startup error. No live UI walkthrough, browser push display, camera/file picker, accessibility or physical-device check was possible. Recent 920 Flutter tests and a web build passed but do not establish these outcomes.

Impact. The deployed experience may still have browser-specific navigation, storage, download, permission or accessibility failures. This is a missing sign-off, not a claim that each listed flow is broken.

Required correction. Run a recorded browser/physical-device acceptance matrix with ordinary and staff roles after security fixes. Include refresh/logout, mobile widths, keyboard/screen reader, uploads/downloads, notifications, QR links, contracts and interrupted-network recovery.

Acceptance. Supported browsers and devices pass the matrix with screenshots/results and no severe defects. A real browser push is displayed and its acknowledgement recorded. Accessibility blockers and permission-denial paths have owners and resolution evidence.

Finding details / PR-23 - PR-24

PR-23 | MEDIUM | Pagination is inconsistent and hides older admin records

Confirmed source behavior • Backend + admin UI • Public web launch

Evidence. admin_control.py:319 returns the latest 200 users with no cursor/page metadata; production has 240 accounts. Search can find selected older records, but browsing cannot enumerate all users. Safety-check/incident and several specialist lists have no explicit result bound.

Impact. Administrators can miss records outside a fixed result cap, while unbounded lists become slow as data grows. Per-user serialization also executes multiple related-count queries. Existing small datasets and passing tests do not prove acceptable production scale.

Required correction. Add consistent bounded cursor pagination, totals where useful and matching UI navigation. Batch related counts and define indexes/query budgets. Keep filters and access scopes intact.

Acceptance. A dataset larger than each page limit can be fully enumerated without omissions/duplicates. Query counts and response sizes stay bounded and older users/records are reachable in the UI.

PR-24 | MEDIUM | Uploads lack account storage budgets and type-content validation

Confirmed source review; abuse load not executed • File pipeline + infrastructure • Public web launch

Evidence. verification.py:391 accepts caller-declared allowed MIME values and files up to 250 MiB (25 MiB for KYC). The binary handler enforces byte limits; file_processing verifies checksum and antivirus. No account-wide storage quota or content-signature validation was found in these paths.

Impact. Clean but wrongly typed files can enter workflows, and repeated valid uploads can consume the remaining disk. Antivirus is important but does not establish that bytes match an image/PDF label. No malicious or bulk file was uploaded to production.

Required correction. Validate file signatures/decoding for each supported purpose, add per-account/project storage budgets and bounded orphan cleanup, and monitor disk reservation. Keep quarantine and ownership gates. Reject unsupported or oversized content before expensive processing.

Acceptance. MIME-spoofed files fail safely; valid supported formats still work. Account quotas cannot be bypassed with repeated sessions. Abandoned files expire under retention rules and scanning failures remain private.

Finding details / PR-25 - PR-26

PR-25 | LOW | OpenAPI omits 119 implemented API operations

Confirmed normalized route comparison • API documentation • Public web launch

Evidence. openapi-drift.json compares live Flask routes to docs/openapi.yaml after removing /api/v1 and normalizing variable names. There are 390 implemented operations and 271 documented operations; 119 implemented operations are missing and no documented operation is unmatched.

Impact. Client developers and security reviewers lack a complete interface contract. This is documentation drift, not evidence that the connected Flutter client fails on those endpoints.

Required correction. Update request/response/auth/error schemas for the missing operations and generate a CI route-contract comparison. Document manual payment, notification delivery and visibility semantics explicitly.

Acceptance. The normalized operation diff is empty and schema tests cover authentication, error envelopes, pagination and key domain state transitions.

PR-26 | HIGH | Android release configuration still uses debug signing

Confirmed source; native-only gate • Mobile release engineering • Native Android/iOS distribution

Evidence. android/app/build.gradle.kts:24 and 37 uses applicationId com.example.cineconnect and signingConfigs.getByName("debug") for release. Native store artifacts/signing, iOS release provisioning and store acceptance were not verified in this audit.

Impact. The repository is not ready for a production Android store release using this configuration. This finding is conditional on native distribution and does not by itself prevent a secured web-only launch.

Required correction. Assign the final package/bundle identity, configure protected release signing and build versioning, and complete platform entitlements, privacy metadata and store/device testing. Keep signing secrets out of Git and general build logs.

Acceptance. A signed release AAB/IPA uses the approved identity and certificate/provisioning, installs on supported devices and passes store validation. Recovery and access controls for signing material are documented.

Finding details / PR-27 - PR-28

PR-27 | MEDIUM | Provider-dependent and unsupported features need explicit launch scope

Confirmed capability state; device delivery unverified • Product + integrations • Depends on advertised product capabilities

Evidence. Live bootstrap: browser push=true with VAPID configured; email=false, SMS OTP=false, liveness=manual_review and social_metrics=self_reported. No native push provider exists. Earlier remediation deliberately disabled unsupported 2FA, biometrics, Urdu, WhatsApp and watermark controls.

Impact. Truthful disabled states are an improvement, but these features cannot be advertised as operational. Browser provider acceptance is not proof of visible delivery. Manual KYC and payment verification require staff capacity and defined escalation.

Required correction. Approve the supported launch feature list and publish matching UI/help text. Test real browser delivery; configure native/SMS providers only when required by the chosen release. Establish staff workflows for manual services and privileged-account protection.

Acceptance. Product claims match tested capabilities. Optional unsupported services are visibly unavailable; required services have real delivery evidence and alerting. Privileged access has an approved MFA or compensating control plan.

PR-28 | MEDIUM | Capacity, concurrency and end-to-end regression evidence is insufficient

Verification gap + measured baseline • QA + performance engineering • Public web launch

Evidence. Fresh HTTP checks were small read-only samples, mostly about 0.38-0.98 seconds from this workstation. No sustained load, soak, failover or payment concurrency test ran. Recent combined coverage is 85.75%, with 90.08% statements but 68.90% branches. New targeted probes exposed eight policy failures despite a green suite.

Impact. Passing unit/integration tests does not establish throughput, p95 latency or correct conflict handling under concurrent writes. Test coverage percentages must not be interpreted as a readiness score. AI provider latency and real bank reconciliation were not exercised.

Required correction. Add adversarial authorization tests from this report, concurrent payment/refresh/upload cases against MySQL, and a realistic staging load/soak plan. Define user volume, latency, queue age and error-budget targets before selecting capacity.

Acceptance. A representative dataset and agreed load meet the documented SLOs without lost/duplicate business effects. All reproduced failures become passing regressions, and failure-recovery tests validate bounded behavior.

9. Dependency and supply-chain review

Installed packages were collected from the running API container. pip-audit used the fully resolved version list; the application distribution itself was excluded from advisory lookup. Duplicate advisory records were consolidated by ID. Dart checks used pubspec.lock against the OSV Pub ecosystem.

Package / scope	Scan result	Triage
cryptography 49.0.0	1 unique advisory	PYSEC-2026-3552 / CVE-2026-69247; reported fixed in 50.0.0. PKCS#7 decryption path not found in app source; private fields use Fernet.
pip 25.0.1	6 unique advisories	Installation/toolchain exposure, not direct HTTP endpoint exposure. Highest reported fix version among matches is 26.2/26.2.0.
Other Python distributions	No returned matches	87 third-party distributions scanned. A clean match result is not proof of absence of unknown flaws.
96 hosted Dart packages	No OSV advisories returned	Flutter/Dart SDK, native OS components and vendored platform libraries are outside this check.
Container / host OS	Not fully scanned	Base image and OS vulnerability scanning remain a release gate under PR-20.

Package	Advisory	CVE alias	Reported fix
cryptography	PYSEC-2026-3552	CVE-2026-69247	50.0.0
pip	PYSEC-2026-1795	CVE-2025-8869	25.3
pip	PYSEC-2026-1796	CVE-2026-1703	26.0
pip	PYSEC-2026-2875	CVE-2026-3219	26.1
pip	PYSEC-2026-2876	CVE-2026-6357	26.1
pip	PYSEC-2026-196	CVE-2026-8643	26.1.2
pip	PYSEC-2026-3721	CVE-2026-13346	26.2

pip CVE-2025-8869 concerns the fallback tar extraction on Python versions without PEP 706; this container runs Python 3.12.13, so that prerequisite is not met. Other pip matches still require installing/downloading untrusted packages or indexes. The Dockerfile disables pip self-update checks, which further narrows that specific advisory path. These observations reduce reachability; they do not replace updating and scanning the build toolchain.

Primary references: R4 (cryptography maintainer advisory), R5 (PyPA advisory database) and R6 (pip release notes). Raw scanner descriptions are not reproduced in this PDF; sanitized IDs and evidence are retained separately.

10. Recovery, capacity and operations

Objective	Current evidence	Launch exit condition
Database recovery	Daily local gzip; latest archive integrity passed.	Encrypted off-host recovery; point-in-time capability meeting approved 15-minute RPO.
Uploaded file recovery	Manual recent snapshots; no scheduled storage job found.	Scheduled versioned file backup and restore with database references.
Service restoration	Rollback assets retained; no complete host-loss drill.	Timed restore within approved 4-hour RTO using independent backup/key access.
Observability	No Sentry DSN; readiness checks only SQL/Redis.	Tested owner alerting for jobs, scan failures, backups, disk and error rate.
Capacity	86% disk, full swap; no container memory/CPU caps.	Measured headroom, resource/log budgets and staging load evidence.
Asynchronous work	Redis RDB snapshots; AOF off; common worker queue.	Durable/reconcilable tasks, bounded retries and queue latency targets.
Antivirus	Daemon/freshclam active; daily database mtime age about 8.8 hours.	Alert on stale signatures and scan outage; demonstrate quarantine and recovery.

Suggested restore drill

On an isolated host, restore an approved encrypted database backup and compatible file snapshot; recover keys through the documented operator process; replay allowed changes; start the recorded immutable release; verify schema, authentication, private documents, contracts and payment balances using synthetic or appropriately protected restored data. Record elapsed time, latest recoverable transaction and mismatches. Do not direct test traffic to production providers.

Performance evidence limits

The web main bundle is 3,610,490 bytes (about 1.03 MB gzip), and local CanvasKit Wasm is 7,155,780 bytes (about 2.88 MB gzip). These are artifact measurements, not total browser transfer or time-to-interactive measurements. Browser network traces, cache behavior and low-bandwidth mobile performance remain unverified.

11. Release acceptance checklist

Stage	Required evidence	Accountable function
Contain access/exposure	Zero seed-default matches; protected backups; private cinema excluded; safety and payment conflict guards tested.	Security, backend, data owner
Establish boundaries	Trusted proxy throttling, database network restrictions, least-privilege DB grants and consistent admin policy.	Infrastructure + backend
Validate trust data	Real staff owners, demo segregation, KYC evidence completeness, missing-file/private-value dispositions.	Product + verification
Prove recovery	Off-host backup success, failure alerts, full restore, RPO/RTO measurement and key recovery.	Backup owner + SRE
Enable core communication	Verified email enrollment/recovery or approved staffed substitute; browser push displayed if advertised.	Integrations + support
Complete product acceptance	Role-based browser/device matrix; accessible interaction; file/camera/download and network-recovery checks.	QA + product
Validate correctness under conflict	MySQL concurrency for payments, signatures, uploads and refresh; duplicate task safety.	Backend + QA
Control release inputs	Pinned artifacts, advisory triage, SBOM, all tests, deployment manifest and rehearsed rollback.	Release engineering
Authorize scoped launch	Every blocker closed; remaining medium risk has named owner, rationale and deadline. Native signing separately approved.	Release owner

No remediation dates or named staff owners were invented. The responsible functions above need actual assignments. A follow-up report should record commit, image, migration and evidence for every closed item, followed by a fresh production smoke test.

Pass criteria

The launch decision changes only when the evidence matches the intended release scope. Public web acceptance does not automatically approve native distribution, automated settlement, biometric identity checks, native push or optional language/features.

12. Remaining verification boundaries

Area	Established	Still required
Security	Selected ownership, anonymous access, proxy/key, seed and permission probes.	Independent broader penetration test, MySQL concurrency and complete role/object authorization matrix.
Frontend	Recent unit/widget tests and JS build; source endpoint wiring.	Fresh UI walkthrough, browser storage/session edge cases, accessibility and real downloads.
Native apps	Source signing issue identified.	Android/iOS release build, physical camera/gallery/push, install/update and store metadata.
AI	Configured provider key; structured stages and limits inspected; baseline mocked tests.	Budget-approved real job, cost/latency targets, document handling and failure recovery.
Payments	Manual bank transfer mode and internal records; isolated self-review reproduced.	Independent bank reconciliation, reviewer operations and concurrent approval correctness.
Privacy / contracts	Version/retention implementation gaps recorded.	Business/legal approval and evidence that operational procedures meet the approved policy.
Infrastructure	App container/host settings and live service checks.	Full OS/image advisory coverage, host-loss restore, sustained load and on-call drill.

Static content review

Searches for mock/demo/TODO/placeholder language were reviewed alongside repositories and API handlers. Labels, skeleton loading placeholders, design constants and intentionally disabled features were not automatically classified as fake business data. Confirmed risks in this report are connected demo data, source-default accounts, incomplete evidence and the specific defects reproduced above. No claim is made that every static literal in 477 Dart files should become a backend field.

Preservation

Application source, existing reports, live services, business records and the intentional local lib.zip archive were left unchanged. This report and its audit evidence are new local artifacts. No GitHub push or production remediation was performed for this audit request.

13. Sources and reproducibility

R1 Flask trusted reverse-proxy configuration

https://flask.palletsprojects.com/en/stable/deploying/proxy_fix/

R2 Docker json-file rotation defaults

https://docs.docker.com/engine/logging/drivers/json-file/

R3 Celery Redis visibility timeout and delivery caveats

https://docs.celeryq.dev/en/stable/getting-started/backends-and-brokers/redis.html

R4 cryptography maintainer advisory GHSA-g6cj-pr64-35w5

https://github.com/pyca/cryptography/security/advisories/GHSA-g6cj-pr64-35w5

R5 PyPA pip advisory PYSEC-2026-3721

https://raw.githubusercontent.com/pypa/advisory-database/main/vulns/pip/PYSEC-2026-3721.yaml

R6 pip release notes

https://pip.pypa.io/en/stable/news/

R7 OWASP ASVS official project

https://github.com/OWASP/ASVS

External references were checked on 14 October 2026. Version matches come from current package inventories and advisory services, not from unverified model recall. No external standard is presented as a certification.

Evidence package

Companion directory: output/production-readiness-2026-10-14/. The PDF embeds selected sanitized machine-readable evidence and the finding register. A companion ZIP contains the fuller audit evidence and the isolated reproduction script. Evidence filenames are cited in finding descriptions; source paths resolve from the repository root.

Fresh evidence includes runtime-data.json, backup-permissions.json, live-controls.json, isolated-probes.json, data-integrity.json, infrastructure.json, runtime-privileges.json, observability.json, openapi-drift.json and package inventories. Retained full test/build evidence remains in output/validation/.

Raw Python advisory descriptions and broad shared-host service inventory are intentionally excluded from embedded report evidence. Secret values and real customer identifiers were never needed for the report. Synthetic IDs in the isolated test are non-production fixtures.